

Research Analyst Registration and Subscription Flow

READ-ONLY TECHNICAL AUDIT REPORT

Audit date 24 July 2026	Scope Registration through research-call creation	Evidence Source tree and supplied PostgreSQL backup
-----------------------------------	---	---

OVERALL RESULT: FAIL

The main flow is substantially implemented, but approval integrity and research-call authorization contain release-blocking defects. No files, database records, application state, payments, registrations, approvals, passwords, emails, or Git state were changed during the audit.

Release-blocking findings

- **Admin identity mismatch:** the authenticated Admin ID originates in `company_users.id`, but approval writes it into `ra_details.approved_by`, whose foreign key targets `users.id`. The transaction can fail and roll back.
- **Missing RA-only authorization:** research-call creation accepts every role supported by the subscription middleware, including Broker and Client, instead of explicitly requiring `RESEARCH_ANALYST`.
- **Password-link exposure risk:** `NODE_ENV` is absent. The approval handler treats every value other than literal `production` as development and may return the plaintext password-setup link.

1. Flow matrix

Stage	Status	Evidence summary	Problem
Registration	PASS	Response returns application_id, registration_token and expiry.	None material.
Session storage	PASS	Validated RA session is stored in sessionStorage and redirected.	Token is accessible to same-origin JS by design.
Plan selection	PASS	Fetches audienceType=RA; sends UUID and x-registration-token.	None material.
Order / retry	PARTIAL	Open local orders are reused; idempotency key is persisted.	Provider order is created before local idempotent write.
Payment verification	PASS	Checks signature, order, amount, currency and captured status.	Success response omits subscriptionStatus.
Admin approval	FAIL	Paid-only checks and activation-at-approval are implemented.	company_users ID is written into users-domain FK.
Password setup	PASS	Used, revoked and expired tokens are rejected; success activates user.	Plain setup URL can be exposed if NODE_ENV is unset.
Login / redirect	PASS	Inactive users rejected; RA redirects to /recommendations.	Suspended-specific branch is masked by generic inactive check.
Research-call create	FAIL	Authentication, feature and usage-limit checks exist.	No explicit RA-role guard.
Expiry / limits	PASS	Expired access denied; exhausted limit returns HTTP 429.	Async finalization should be monitored.

2. Key code evidence

Registration and browser session

- Backend response fields: backend/src/controllers/registration.controller.ts, lines 980-987.
- Session storage implementation: frontend/src/features/raRegistrationSubscription/session.ts, lines 16-101.
- Registration response validation and redirect: frontend/src/pages_registration/RegistrationPage.tsx, lines 292-354.

Plan and payment

- RA plan filter and token header: frontend/src/features/raRegistrationSubscription/api.ts, lines 180-185 and 402-407.
- Plan selection/order/verification requests: api.ts, lines 429-478.
- Order reuse and idempotency: backend/src/controllers/registrationPayment.controller.ts, lines 314-370 and 397-469.
- Signature and provider-state verification: backend/src/controllers/registrationPaymentVerification.controller.ts, lines 300-410.
- Paid transitions: registrationPaymentVerification.controller.ts, lines 639-799.

Approval and password setup

- Paid-only approval checks: backend/src/controllers/adminSubscriptionApproval.controller.ts, lines 282-359.
- Inactive user creation: adminSubscriptionApproval.controller.ts, lines 416-460.
- Subscription begins at approval: adminSubscriptionApproval.controller.ts, lines 530-560.
- Password token hashing: adminSubscriptionApproval.controller.ts, lines 591-628.
- Token validation and activation: backend/src/controllers/passwordSetup.controller.ts, lines 128-198 and 454-519.

Login and research calls

- Inactive login rejection: backend/src/controllers/auth.controller.ts, lines 177-190.
- RA redirect: frontend/src/common/LoginForm.tsx, lines 75-82.
- /recommendations route: frontend/src/routes/AppRoutes.tsx, lines 177-184.
- Research-call middleware chain: backend/src/routes/researchCalls.routes.ts, lines 16-29.
- Expiry and usage-limit enforcement: backend/src/middlewares/subscriptionAccess.middleware.ts, lines 137-275 and 655-824.

3. Database evidence

Most recent test RA

Item	Current value
RA entity	c7346ff9-0e17-46e8-8448-7e6d6b571fbc
Registration application	c1559df5-6d6f-4e1d-96d9-02523ca3e99f
RA / application state	pending / PAYMENT_PENDING
Selected plan	RA_TIER_2_V1 - 200 paise
Payment order	CREATED
Transaction / subscription / user / setup token	None / None / None / None

Backup evidence locations

- RA row: 24july_codex_plainbackup.sql line 1939.
- Application row: line 1994; plan selection: line 2007; payment order: line 1895.
- Most advanced new-flow registration: application 47e9c560-9c4e-492c-98e8-be0606085c3c is PAID_PENDING_APPROVAL with a captured transaction and pending subscription, but no user.

Foreign-key targets

ra_details.approved_by -> users.id	password_setup_tokens.user_id -> users.id
password_setup_tokens.registration_application_id -> registration_applications.id	payment_orders.registration_application_id -> registration_applications.id
payment_orders.plan_selection_id -> registration_plan_selections.id	payment_orders.user_id -> users.id
payment_transactions.payment_order_id -> payment_orders.id	registration_applications.user_id -> users.id
registration_plan_selections.registration_application_id -> registration_applications.id	registration_plan_selections.plan_id -> subscription_plans.id
subscription_events.subscription_id -> subscriptions.id	subscription_plan_features.plan_id -> subscription_plans.id
subscription_plan_features.feature_id -> subscription_features.id	subscription_plan_limits.plan_id -> subscription_plans.id
subscriptions.user_id -> users.id	subscriptions.registration_application_id -> registration_applications.id
subscriptions.plan_id -> subscription_plans.id	subscriptions.payment_order_id -> payment_orders.id

4. Foreign-key and identity findings

- Admin login queries `company_users`; its ID is placed in the JWT and copied to `req.user.id`.
- Approval uses that value as `adminId` and writes it to `ra_details.approved_by`, `registration_applications.approved_by`, `subscriptions.approved_by`, and subscription event actor fields.
- `ra_details.approved_by` explicitly references `users.id`; the identity domains are incompatible.

Columns missing relevant FK constraints

- `registration_applications.approved_by` and `rejected_by`
- `subscriptions.approved_by`
- `subscription_events.actor_user_id`
- `subscription_plans.created_by` and `updated_by`
- `ra_details.user_id`

5. API contract mismatches

- Payment verification changes the subscription to `PAID_PENDING_APPROVAL` but omits `subscriptionStatus` from the success response.
- The frontend type was relaxed to omit `subscriptionStatus` rather than aligning the API response with the state transition.
- Both `ADMIN_APPROVAL` and `WAIT_FOR_ADMIN_APPROVAL` are accepted as `nextStep` values; one canonical value should be used.
- The approval request field is named `userId` although its value is a details/entity ID.

6. Security findings

- **Critical:** Admin identity mismatch can block approval and corrupt actor attribution where no FK exists.
- **High:** missing explicit RA authorization on research-call creation.
- **High:** plaintext password setup URL can be included in approval responses when `NODE_ENV` is absent.
- **Medium:** public legacy OTP endpoints remain enabled.
- **Medium:** temporary public test routes remain enabled.

7. Retry and idempotency findings

- The frontend avoids selecting the same saved plan again.
- The backend reuses existing open local payment orders.
- Payment verification locks application and order rows and returns an idempotent success for an existing verified transaction.
- Approval returns an already-approved response without creating a second user or subscription period.
- **Remaining gap:** Razorpay order creation precedes the local idempotent database write, leaving a narrow orphan/duplicate-provider-order window.
- The frontend recovery path trusts session status; an authoritative status endpoint would be safer.

8. Ordered recommended fixes

1. Establish one compatible Admin identity model. Reference company_users where appropriate or introduce a unified principal table.
2. Add explicit requireResearchAnalyst middleware before subscription middleware on research-call creation.
3. Do not expose password-setup URLs based on NODE_ENV inequality. Use an explicit, default-off development flag.
4. Add or correct foreign keys for all user, approval and actor columns.
5. Return subscriptionStatus and standardize the payment verification nextStep value.
6. Rename approval userId to entityId or registrationApplicationId.
7. Reserve the local idempotency record before creating a Razorpay order and add reconciliation.
8. Remove or production-gate legacy OTP and test endpoints.
9. Add an authoritative registration-status endpoint for retry/recovery.
10. Resolve existing frontend TypeScript failures and add isolated side-effect-free flow tests.

9. Files that would need changes

```
backend/src/controllers/adminSubscriptionApproval.controller.ts
backend/src/routes/admin.routes.ts
backend/src/routes/auth.routes.ts
backend/src/routes/researchCalls.routes.ts
backend/src/middlewares/subscriptionAccess.middleware.ts
backend/src/controllers/registrationPayment.controller.ts
backend/src/controllers/registrationPaymentVerification.controller.ts
frontend/src/features/raRegistrationSubscription/api.ts
frontend/src/features/raRegistrationSubscription/types.ts
Database migration files and deployment environment configuration
```

10. Read-only SQL

No SQL was executed against a live database. Only the supplied plain SQL backup was inspected because restoring it would create database objects and violate the audit rules. The following SELECT-only query reproduces the principal state audit when run against an authorized live database:

```
SELECT
  app.id AS application_id,
  app.status AS application_status,
  sel.id AS selection_id,
  plan.plan_code,
  po.id AS payment_order_id,
  po.status AS payment_order_status,
  pt.status AS transaction_status,
  sub.id AS subscription_id,
  sub.status AS subscription_status,
  u.id AS user_id,
  u.status AS user_status,
  u.is_active,
  (u.password_hash IS NOT NULL) AS has_password,
  pst.used_at, pst.revoked_at, pst.expires_at
FROM registration_applications app
LEFT JOIN registration_plan_selections sel
  ON sel.registration_application_id = app.id
AND sel.replaced_at IS NULL
LEFT JOIN subscription_plans plan ON plan.id = sel.plan_id
LEFT JOIN payment_orders po ON po.registration_application_id = app.id
LEFT JOIN payment_transactions pt ON pt.payment_order_id = po.id
LEFT JOIN subscriptions sub ON sub.registration_application_id = app.id
LEFT JOIN users u ON u.id = app.user_id
LEFT JOIN password_setup_tokens pst
  ON pst.registration_application_id = app.id
WHERE app.applicant_type = 'RA'
ORDER BY app.created_at DESC;
```

11. Validation and audit integrity

- Backend TypeScript: PASS using tsc --noEmit --incremental false.
- Frontend TypeScript: four existing errors in unrelated price and subscription page components.
- Before and after git status --short, git diff --stat and git diff were identical.
- Baseline contained nine pre-existing modified files: 294 insertions and 118 deletions.

READ-ONLY AUDIT COMPLETE

FILES CHANGED: NONE

DATABASE CHANGED: NO

GIT STATE CHANGED: NO